01 / CONTOSO TODAY

Meet Contoso and its ordering service

Contoso is a fictional retailer. This case follows its ordering service from normal operation through a security investigation, then replays that work with bounded agent assistance.

TODAY	Existing systems	HIL	Human in the loop	PAIN	Manual work or delay	VERIFY	Evidence and service checks

Business context: customers depend on a working order journey

Customers place orders, search their order history and check fulfilment status. The C# ordering API reads and writes order records in Azure SQL. Contoso must protect customer data while keeping legitimate orders moving.

50 engineers

Develop and maintain the retailer's applications. An ordering service engineer owns this code investigation.

6 SOC analysts

Handle security alerts and incidents alongside other cases. The duty analyst owns the incident assessment.

4 SREs

Operate production services. The duty SRE owns deployment health, monitoring and an authorized rollback.

Application and security estate

Azure DevOps stores the C# repository and runs the release pipeline. App Service hosts the API. Azure SQL holds order data. Existing scanners, Defender and service telemetry provide separate security signals.

Decision ownership and business stakes

The CISO sets risk limits. The architect assesses exposure. The service owner approves disruptive action. A broad shutdown can interrupt ordering. An incomplete investigation can leave customer data at risk.

02 / CONTOSO TODAY

Follow the service and release flows today

Today, Contoso already has automation, monitoring and change controls. People connect those systems during an investigation. The baseline is not an unprotected or entirely manual SOC.

TODAY Existing systems | HIL Human in the loop | PAIN Manual work or delay | VERIFY Evidence and service checks

A CUSTOMER REQUEST AND DATA FLOW

Customer	C# ordering API	Orders database
Place, search or track an order	Azure App Service Application authorization	Azure SQL Scoped data access

B SOFTWARE CHANGE AND RELEASE FLOW

Azure DevOps	Release pipeline	Production service
Engineer changes code. Reviewer checks the diff.	Build, scanner and tests. Owner approves release.	Staged deployment. SRE checks service health.

C SECURITY SIGNAL AND INVESTIGATION FLOW

Separate inputs	People and queues	Manual handoff
Scanner findings, Defender and application telemetry	Engineer and SOC analyst investigate in their tools.	Tickets, notes and reports support the owner's decision.

Scenario assumptions: managed identity, scoped database access, staged release and usable telemetry. A code finding does not itself prove that access controls failed.

03 / THE SECURITY SCENARIO

Open the Contoso security case

Monday, 09:00 in the teaching scenario: a code scan flags unsafe query construction. A Defender incident points to suspicious activity around the same ordering API.

TODAY Existing systems | HIL Human in the loop | PAIN Manual work or delay | VERIFY Evidence and service checks

Signal 1: the scanner finding

Request input from an order search filter appears to be concatenated into an SQL query. The finding identifies a candidate code path, not a verified vulnerability. The engineer must check validation, query construction and parameter binding.

Signal 2: the Defender incident

Incident INC1042 contains suspicious activity associated with the ordering service. The analyst must identify affected entities, reconstruct events and assess the evidence. Sharing an API name does not establish exploitation of the scanner finding.

A concrete code hypothesis for the engineer to investigate

Order search input	→	Query construction	→	SQL execution
Customer supplied filter enters the request handler.		Candidate path combines input with query text.		Engineer checks the sink, parameter binding and scope.

Case C017: one service, two signals and a decision still to make

Illustrative identifiers: incident INC1042 and commit a1b2c3d. The coordinator starts a manual case record. The teams must verify the deployed version, establish any relationship, determine response scope and retain a safe release path.

04 / CURRENT RESPONSE

Investigate with the current SOC

The duty analyst and ordering service engineer work in parallel. Their conclusions must be joined manually before the service owner can make an informed response decision.

TODAY Existing systems | HIL Human in the loop | PAIN Manual work or delay | VERIFY Evidence and service checks

Stage	Owner	Work performed today	Evidence handed forward
1 Intake	SOC analyst + engineer	Log INC1042 and the scanner ticket. Identify the ordering service owner. Start the manual C017 record.	Incident and finding IDs. Named owners. Separate investigation tickets.
2 Scope	Analyst + SRE	Map the alert entities to the API and environment. Check the deployed commit and the relevant event window.	Resource identity, deployment version and investigation time range.
3 Collect	SOC analyst	Retrieve supported Defender evidence and service logs. Request missing records from SRE. Note coverage gaps.	Source records, timestamps and an explicit list of missing telemetry.
4 Verify code	Engineer	Trace the filter through the C# code to the query sink. Inspect binding and validation. Reproduce safely in a test environment.	Verified flaw or dismissal rationale. Reproduction and affected code path.
5 Reconstruct	SOC analyst	Build the incident timeline. Assess suspicious requests and entities. Check whether traces reach the affected deployed code.	Incident verdict, affected entities and evidence for or against a relationship.
6 Assess risk	Architect	Review reachability, application authorization and database privileges. Relate technical exposure to customer impact.	Exposure assessment, service importance and proposed response priority.

Handoff: the engineer's code evidence and the analyst's incident evidence are separate until people reconcile them.

05 / CURRENT RESPONSE

Decide, remediate and recover today

The current workflow continues beyond diagnosis. Contoso must authorize action, correct the code, deploy safely, verify the service and reconcile the security and engineering records.

TODAY Existing systems | HIL Human in the loop | PAIN Manual work or delay | VERIFY Evidence and service checks

Stage	Owner	Work performed today	Evidence handed forward
7 Reconcile	Analyst + engineer	Compare commit, resource, code path and event window. Resolve conflicting reports. Separate verified facts from hypotheses.	Manual C017 summary with linked reports, unresolved questions and proposed action.
8 Approve	Service owner + architect	Review containment scope, customer impact and recovery. Escalate beyond delegated risk limits to the CISO.	Authorized response, release scope and named decision owner.
9 Correct	Engineer + reviewer	Replace unsafe query construction with parameter binding. Review authorization. Test valid filters, malformed input and regressions.	Reviewed branch, test evidence and deployment candidate.
10 Deploy	SRE + pipeline	Run existing release checks and staged deployment. Stop expansion when health checks fail. Use the authorized rollback path.	Release record, deployed version and checks for the staged rollout.
11 Verify	SRE + analyst	Check order submission and lookup, errors, latency and SQL load. Review incident activity and any residual exposure.	Service health evidence and the SOC's updated incident assessment.
12 Close	Analyst + owner	Reconcile scanner rescan, deployed fix and incident status. Record remaining risks and follow-up detection work.	Aligned case closure, separate ticket updates and retained audit evidence.

Human judgment is not the problem. The pain is the repeated preparation and coordination needed to support it.

06 / CURRENT PAIN POINTS

Locate the pain in the current workflow

The bottleneck appears between tools and teams, not only inside a scan or alert queue. Each pain point below is tied to a stage in Contoso's current response.

TODAY Existing systems | HIL Human in the loop | PAIN Manual work or delay | VERIFY Evidence and service checks

1 Intake and scope: fragmented context

The scanner and Defender use different records. People reconcile repository, API, resource and deployed commit. A wrong version match can send both teams down an irrelevant investigation.

2 Collection: evidence requests

The analyst depends on SRE for missing application or deployment records. Collection interrupts operations and can leave the investigation waiting while other incidents accumulate.

3 Analysis: repeated reconstruction

The engineer traces code while the analyst rebuilds the service timeline. Both reconstruct ownership and deployment context. Experts spend time assembling facts before applying judgment.

4 Reconciliation: uncertain causality

The code ticket and incident report can imply different scope or severity. Shared asset identity is mistaken for proof of exploitation unless reviewers explicitly compare supporting evidence.

5 Approval: incomplete decision packets

The owner needs a tested fix, exposure assessment, customer impact and recovery plan. Missing evidence creates another handoff rather than a defensible authorization.

6 Closure: duplicated records

SRE, engineering and SOC update separate artifacts. A deployed patch can be mistaken for incident resolution unless someone verifies security outcomes and service health together.

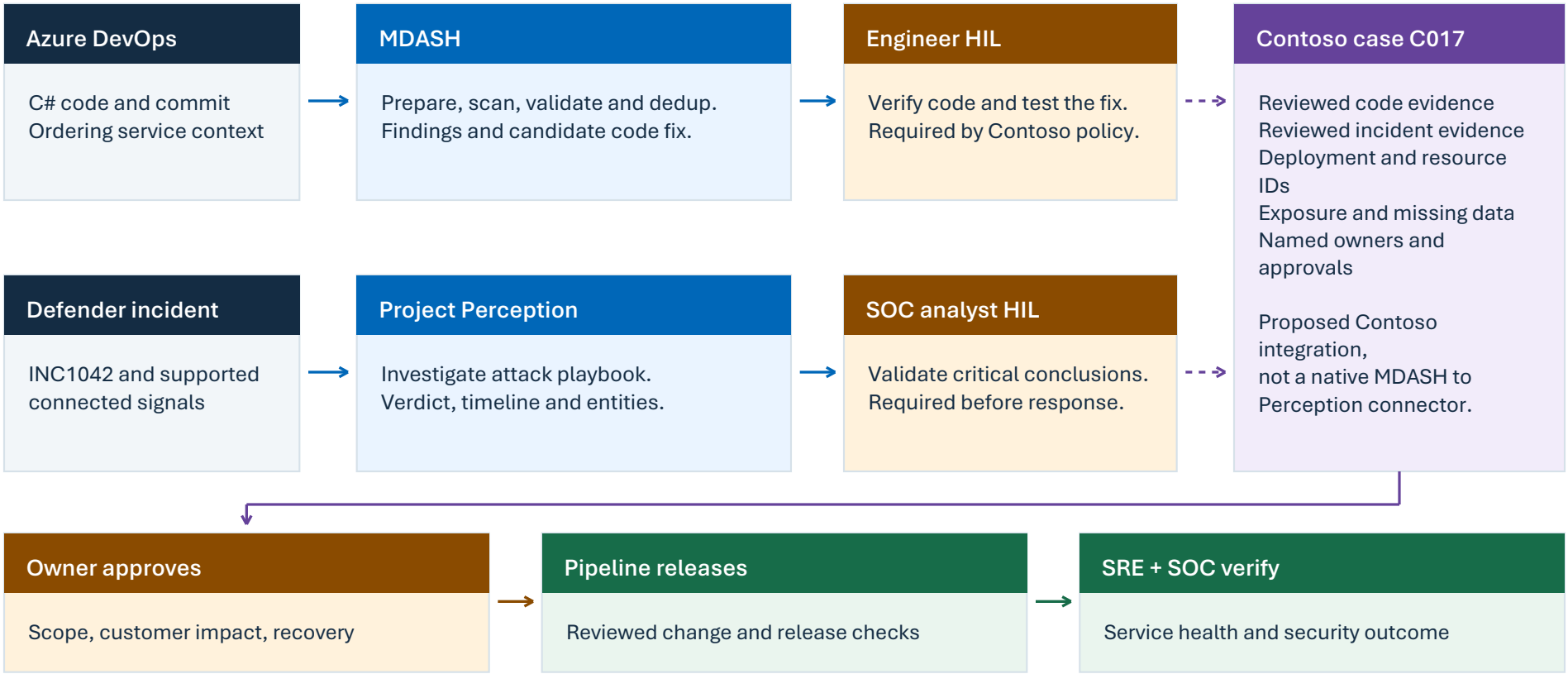
07 / THE AGENTIC TRANSFORMATION

Introduce the agentic operating model

Contoso now delegates evidence preparation, not production authority. MDASH supports code security. Project Perception supports the SOC investigation. Neither replaces the other.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

Target design: two independent analysis paths, one reviewed response record



AI changes how evidence reaches a decision. Existing application access, release approval and recovery controls remain.

08 / THE AGENTIC TRANSFORMATION

Transform the code investigation

Replay the code investigation for commit a1b2c3d. The engineer gives MDASH the approved repository scope and reviews its findings against the code that actually runs in production.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

Replace manual discovery with agent prepared code evidence

MDASH uses specialized auditors, code context and multi-model validation to investigate the candidate flaw. Its result can accelerate the engineer's work, but confidence alone does not establish correctness.

1 Prepare	2 Scan	3 Validate	4 Dedup
Rank the C# code using call graph and complexity. Prioritize risky paths.	Specialized auditors analyze the order search input and query context.	Taint and type analysis, with model debate, test the candidate finding.	Consolidate findings. Publish unique results with confidence.

Evidence the engineer receives

Preserve the source parameter, query sink, call path, rationale, confidence and exact commit. Check whether existing parameter binding or validation defeats the finding. A runnable dynamic proof is not guaranteed for every code path. Disputed findings stay unresolved.

Required HIL: verify and test the correction

MDASH can generate and apply a candidate fix through Defender CLI. Contoso applies it to a review branch. The engineer checks parameter binding, authorization and regressions. The reviewed diff and tests enter C017. Agents receive no production release authority.

09 / THE AGENTIC TRANSFORMATION

Transform the incident investigation

Replay INC1042 while code analysis proceeds independently. The analyst launches Investigate attack from the incident context and examines the Perception session as the work develops.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

Scoped input

Incident ID and permitted
Defender context.
Connected sources only.

→

Attack Investigation

Correlate signals and entities.
Prepare the attack story
and response evidence.

→

Analyst review

Check verdict and timeline.
Inspect sources and gaps.
Redirect disputed work.

What changes in C017

Instead of assembling the first incident narrative from scratch, the analyst reviews a verdict, timeline, attack graph, affected entities and remediation guidance. They validate source records and compare deployment context with the engineer. Missing logs remain missing evidence, not inferred facts.

Architect review: exposure and priority

Where needed, Recon assesses visible Azure resources in read only mode. Posture Prioritization ranks relevant gaps. The architect checks reachability, identity scope and business importance. These tasks do not exploit or remediate resources.

Recommended HIL: session supervision

Contoso recommends progress checks during longer sessions. Agent identities constrain access. Session records retain activity and outputs. Analysts can redirect, reject or stop work. Optional Detection Authoring drafts candidate KQL for engineer testing before publishing.

10 / THE SAME CASE, REPLAYED

Resolve the same case with reviewed evidence

C017 joins reviewed results rather than merely collecting agent outputs. The evidence must show whether the suspicious activity reached the verified query path in the deployed application.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

Worked outcome for this fictional case

The engineer confirms unsafe query construction in commit a1b2c3d. The analyst checks request traces against that deployment and finds evidence of attempted abuse of the affected path. Customer data loss is not established. The owner approves a tested correction and proportionate response.

Reviewed C017 record	Required owner HIL	Controlled response
Code path, incident timeline, resource, version and gaps. Owners retain source evidence.	Approve containment and release. Review customer impact. Escalate beyond CISO limits.	Pipeline stages the correction. SRE verifies order processing. SOC reviews residual activity.

Acceptance and recovery

Test valid order filters and malformed input. Verify authorization, errors, latency and SQL load. Rescan the reviewed change and check incident evidence. SRE stops rollout or uses the authorized rollback if health degrades. Stopping an agent is not rollback.

Alternative: no proven relationship

Keep the code flaw and incident on separate decision paths when correlation is unsupported. Fix the verified flaw through normal change control. Investigate or close INC1042 on its own evidence. A merged report must not turn uncertainty into a breach claim.

11 / THE TRANSITION

Move Contoso from current to target operations

The move to an agentic SOC is an operating model change, not a replacement project. Contoso starts with the ordering service and expands only after it can demonstrate reliable, bounded assistance.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

1 Baseline the ordering service

Keep the current workflow and owners visible. Record manual handling, evidence requests, approval rework and decision quality. Inventory telemetry and map repository to deployed service.

2 Onboard scoped analysis

Connect approved code to MDASH with a dedicated Foundry resource and feature scoped Defender roles. Configure Perception agent identities and supported signals. Test permissions and source coverage.

3 Run assisted cases first

Engineers and analysts review every pilot output. Retain the original records. Test false findings, missing logs, rejected actions and stopping. Define the C017 handoff without assuming a native connector.

4 Expand within explicit limits

Choose supported event or scheduled triggers after quality review. Retain gates for consequential action. Monitor errors, drift and cost. Optional SRE AIOps assistance is Contoso's design, not a Perception feature.

Microsoft AI governance at the points where it matters

Identity: separate scan, investigation and release authority. Data: approve sources, retention and prompt processing locations. Purview coverage depends on supported applications and data paths. Review: retain Perception sessions, engineer tests and owner approval. Assurance: evaluate incorrect conclusions and missing evidence. Confirm support and licensing for extended Entra and Guardian controls. Independent controls enforce authority, not the model. Guardian integration is not assumed within MDASH.

12 / BEFORE AND AFTER

Compare the operating models and measure value

The comparison keeps Contoso's service, signals and accountability constant. Expected value comes from less repeated evidence preparation and better handoffs, not from removing expert judgment.

AGENT Delegated analysis | HIL Human in the loop | GOV Governed access and action | VERIFY Evidence and service checks

Same work	Current workflow	Agentic target workflow
Code investigation	Engineer manually traces the scanner finding and assembles evidence.	MDASH prepares consolidated code findings and a candidate fix. Engineer verifies the path and tests the change.
Incident investigation	Analyst collects signals and constructs the first incident narrative.	Perception prepares the attack story. Analyst checks sources, gaps and critical conclusions.
Cross-team decision	People reconcile separate tickets, deployment context and reports.	Contoso's C017 handoff links reviewed records. Architect and service owner retain response authority.
Release and closure	Engineer, SRE and SOC verify through existing controls and separate records.	Keep those controls. Join code, incident and service evidence. Agents do not authorize release or prove closure.

Measure net handling and review time, missed findings, approval rework, service impact and total usage and integration cost. This fictional case does not establish measured savings.

Official Microsoft references

MDASH overview | MDASH setup | Perception application card | Agent categories

Entra Agent ID | Purview for AI | Guardian architecture

Let's continue the conversation.

Make your next security move with confidence.

Razi Rais

Your trainer. Author. Security practitioner.

LINKEDIN

Stay connected.

Ask a question. Share an idea.
Keep learning together.

Connect with Razi →

MORE LIVE TRAINING

Choose your next session.

Zero Trust for AI Systems
Hands-On Microsoft Foundry
Anatomy of a Cyberattack

See all sessions + dates →

ADVISORY CONVERSATION

Bring your next challenge.

Explore an advisory session.
Start with your goals.

SCAN TO START

Open the inquiry form →

razibinrais.com/contact